

| PRACTICAL GUIDE

Essential Eight

A practical guide

What the ASD Essential Eight actually requires, where the obligation sits, and what an Australian small or medium business can realistically do about it.

WRITTEN FOR

Australian SMBs

EVIANT PTY LTD

VERSION

1.0 · Free to share

What this guide is for

The Essential Eight is the most referenced cyber security baseline in Australia and one of the most misrepresented. This guide sets out what it actually requires, where the obligation genuinely sits, and what a small or medium business can realistically do about it.

In its Annual Cyber Threat Report for 2024 to 2025, the Australian Signals Directorate recorded more than 84,700 cybercrime reports and an average self-reported cost of \$56,600 per report for a small business. Of the 138 ransomware incidents the ACSC handled, 39 per cent were found by the ACSC rather than the victim, and 42 per cent of the most serious incidents involved compromised credentials. Businesses are mostly not being outsmarted. They are being logged into, and finding out late.

| SECTION 01

What is the Essential Eight?

The Essential Eight is eight controls the Australian Signals Directorate selected from a much longer list of mitigation strategies, on the basis that they stop the most attacks for the least effort. Four aim to stop an attacker getting in. Three limit what they can reach once inside. One gets the business running again afterwards.

ASD wrote the model for internet connected enterprise IT, meaning managed Windows devices and servers on a network you control, so a business running entirely on cloud services has to reason by analogy against several of the eight. It is also a baseline rather than a security programme, and says nothing about staff training, incident response or vendor risk. Those gaps are deliberate, so the model stays achievable. Treat it as the floor.

| SECTION 02

Where the obligation sits

Non-corporate Commonwealth entities have been required to implement all eight strategies to Maturity Level 2 under the Protective Security Policy Framework since 1 July 2022. For everyone else in the private sector, the Essential Eight is recommended, not legislated. Anyone telling you otherwise is selling fear.

That leaves plenty of obligation. Several regimes require you to protect information without saying how, and the Essential Eight is the reference most often used to show you took reasonable steps.

REGIME	WHAT IT REQUIRES
Privacy Act, APP 11	Above \$3 million turnover, you must take reasonable steps to protect personal information. Reasonable is undefined, which is the point.
Notifiable Data Breaches	Where a breach is likely to cause serious harm, you must notify affected individuals and the OAIC.
Tax File Number Rule	Any organisation receiving an individual's tax file number must comply with the Privacy (Tax File Number) Rule 2015, regardless of turnover. The small business exemption does not reach it.

REGIME	WHAT IT REQUIRES
APRA CPS 234	Regulated entities must maintain and test information security capability. Prescriptive, and audited.
Ransomware reporting	Businesses above \$3 million turnover must report a ransomware payment to government.
Contracts and insurance	The sharpest edge in practice. Government supply chain terms, vendor reviews and insurance questionnaires now ask for Essential Eight maturity by name.

THE POINT MOST BUSINESSES MISS

The small business turnover exemption is narrower than people assume. Handling tax file numbers, trading in personal information, or providing a health service all pull you back in regardless of size.

Some professions carry their own version. Registered tax and BAS agents have been subject to section 30 of the Tax Agent Services Code of Professional Conduct Determination 2024 since 1 July 2025, under which the Tax Practitioners Board expects adequate procedures, policies, systems and controls to protect the security and confidentiality of client records. None of it names the Essential Eight. All of it creates the same problem: you are expected to have done something sensible, and to be able to show it.

| SECTION 03

The four maturity levels

Each strategy is scored from Level 0 to Level 3. The levels describe the attacker you are defending against, not the effort you have spent.

LEVEL	WHAT IT MEANS
ML0	Weaknesses remain that would allow a compromise. Where most businesses start, including ones that have been trying.
ML1	Defends against attackers using widely available tools, looking for any victim rather than for you specifically. The realistic first target for most small businesses.
ML2	Defends against attackers willing to spend more time and better tooling on a target, and better at avoiding basic detection. The usual contractual requirement.
ML3	Defends against adaptive attackers who do not rely on public tools and who move quickly once inside.

Implement all eight to your target level before advancing any further. An attacker takes the easiest path available, so Level 1 across all eight protects you considerably better than Level 3 across three of them. For scale, ASD assessed federal entities in 2025 and found 22 per cent had reached Level 2 overall. Those entities have been legally required to hold Level 2 since 2022. If you are sitting at Level 0 today, you are in ordinary company.

| SECTION 04

The eight strategies

What each one asks at Maturity Level 1, and the reason it usually fails. Costs assume 20 to 60 staff already on Microsoft 365 and are indicative.

STRATEGY	WHAT LEVEL 1 ASKS	WHERE IT USUALLY FAILS
Application control	Only approved software runs. Blocks execution from the folders users can write to, which is where downloads and email attachments land.	Deployed straight to enforce mode without two weeks in audit first, generating complaints and then getting switched off.
Patch applications	Automated asset discovery, weekly scanning of browsers, Office, email and PDF software, patching within a month, and removal of anything the vendor no longer supports.	Patching happens but nothing scans, so the business cannot prove it. This is why businesses that patch well still score Level 0.
Patch operating systems	Fortnightly scanning of workstations, servers and network devices, daily for internet facing services, patched within a month.	Firewalls and VPN appliances. They face the internet, are rarely rebooted, and have been the entry point in a large share of Australian incidents.
Multi-factor authentication	MFA on your internet facing services and on third party services holding your sensitive data.	Exclusions. Service accounts, integrations and contractors get excluded and never reviewed. Compromised credentials featured in 42 per cent of ASD's most serious incidents.
Restrict administrative privileges	Privileged access validated when granted, separate accounts for administrative and ordinary work, and admin accounts blocked from email and the web.	In a small business the administrator is also a normal employee reading email all day, from one account that does both. It is the highest value target you have.

STRATEGY	WHAT LEVEL 1 ASKS	WHERE IT USUALLY FAILS
Configure Office macro settings	Macros disabled for anyone without a demonstrated need, internet sourced macros blocked, antivirus scanning on, and users unable to change the setting.	Left at the default because nobody asked. Where exceptions exist they are granted verbally and never written down.
User application hardening	Browsers do not process Java or web advertisements from the internet, Internet Explorer 11 is disabled, and users cannot change browser security settings.	Advertisement blocking gets waved away as a convenience measure. Malicious advertising needs no user error beyond visiting an ordinary website.
Regular backups	Backups performed and retained to business continuity needs, restoration tested, and ordinary accounts unable to reach, modify or delete them.	No restore test, so nobody knows recovery time until it matters. Worse, the admin accounts most likely to be compromised can also delete the backups.

Table 1. The eight strategies at Maturity Level 1.

What it costs

Already included	Multi-factor authentication, administrative separation, Windows LAPS, macro settings, Internet Explorer removal, backup permissions. No licence cost, mostly a day or two of configuration each.
Included, needs work	Application control ships with Windows Enterprise and Microsoft 365 Business Premium. Three to five days to deploy properly.
Small monthly cost	Vulnerability scanning, roughly \$5 to \$15 per user per month at this size. Enterprise tooling costs considerably more and is not required at Level 1.
Time, not money	A restore test costs a day and is the single most valuable thing on this page.

| SECTION 05

How scoring works

A level is awarded only where every requirement at that level, and every level below it, is met. No partial credit and no averaging. One unmet requirement holds the whole strategy at the level below.

Your overall maturity is your lowest strategy, not your average. Six at Level 2 and two at Level 0 is an organisation at Level 0. Where a report quotes an average across the eight, it has invented a number that does not exist in the model.

| SECTION 06

A ten minute self-check

This will not produce a maturity rating. It will tell you roughly where you stand and which conversation to have first. Answer honestly, including where the honest answer is that you do not know. Not knowing is itself a finding.

#	QUESTION	IF NO OR UNSURE
1	If an employee downloaded and ran an unknown program right now, would anything stop it?	Application control
2	Can you produce a list of every device missing a security patch today?	Patch applications
3	When was your firewall firmware last updated?	Patch systems
4	Can someone name every account excluded from multi-factor authentication?	MFA
5	Does whoever administers your systems read email from that same account?	Admin privileges
6	Would a spreadsheet with macros from an unknown sender be blocked?	Office macros
7	Are web advertisements filtered before they reach staff browsers?	App hardening
8	When did you last restore a system from backup, as a test rather than an emergency?	Backups

#	QUESTION	IF NO OR UNSURE
9	If your main administrator account were compromised tonight, could the attacker delete your backups?	Backups
10	Could you tell what a specific user did three months ago?	Logging
8 or more yes	Better shape than most. An assessment will largely confirm it and give you evidence to hand to a client or insurer.	
4 to 7 yes	The common position. Real controls with specific gaps, usually cheaper to close than expected.	
3 or fewer yes	Start with questions 4, 5 and 9. Most risk for least cost, and none requires a purchase.	

| SECTION 07

Where to start

This assumes a business starting near zero, on Microsoft 365, with no dedicated security staff. It front loads the work that costs nothing. The detail from here is written to be forwarded to whoever runs your systems, whether that is someone internal or an external provider.

First 30 days, no purchase required

- Separate administrative accounts from daily accounts, and block the administrative accounts from email and browsing.
- List every account excluded from multi-factor authentication, then remove the exclusions you cannot justify in writing.
- Create a backup administrator account separate from your tenancy administrators, and turn on immutable retention.
- Set Office macros to blocked, with recorded exceptions for anyone with a genuine need.
- Disable Internet Explorer and confirm Java is absent from the standard build.

Days 30 to 90, the two real capabilities

- Add vulnerability scanning. Without it, two strategies cannot pass Level 0 however well you patch.

- Deploy application control in audit mode, build the ruleset from what your business actually runs, then enforce.
- Perform a full restore test to an isolated network and time it. Set your recovery objective from the result rather than the other way round.
- Extend log retention beyond the 30 day default. Incidents are routinely found later than that.

Days 90 to 180

- Shorten patch windows from one month to two weeks, using scan data to verify rather than assume.
- Extend application control to servers.
- Put review cycles on administrative access and MFA exclusions, with a named owner.
- Repeat the restore test and make it a standing six monthly commitment.

A REALISTIC EXPECTATION

A business starting near zero can reach Level 1 across all eight in roughly three months of part time effort, and Level 2 in six to nine. Anyone promising Level 2 in a fortnight is describing a purchase rather than a change.

d | SECTION 08

Four things that are not progress

Assuming the cloud handles it

Microsoft and Google secure their platforms. They do not configure your conditional access policies, decide who holds administrative roles, or test whether you can restore. Most of the Essential Eight sits on your side of the shared responsibility line.

Buying a product described as Essential Eight compliant

No product delivers the Essential Eight. The strategies span configuration, process, access management and recovery testing. A tool helps with several. None covers all eight, and a restore test is not something you can purchase.

Completing a questionnaire and filing the result

A self-assessment where every answer is yes and no evidence is attached offers no protection and little assurance. When an insurer or a client asks how you knew, the answer needs to be better than that somebody ticked a box.

Treating it as a project with an end date

Maturity decays. Exclusions get added, staff change, new software arrives, and ASD moves the bar. A position established once and never revisited will not survive two years. An annual review is the minimum that keeps an assessment meaningful.

IF YOU TAKE ONE THING FROM THIS GUIDE

Find out today whether your administrative accounts are also used for email, and whether those accounts can delete your backups. Those two questions account for much of the difference between an incident and a catastrophe, and neither costs anything to answer.

About Eviant

Eviant is a Sydney based cyber security firm working with small and medium businesses and professional practices across New South Wales. Our consultants have hands on incident response experience, so we have seen which controls hold and which look reassuring in a report and fail on the day.

Essential Eight maturity assessment

A fixed fee assessment against the ASD model. Evidence based rather than questionnaire based, which means we collect configuration, test controls where testing is safe, and record what we found with dates against it.

- A maturity level for each strategy, with the specific requirement holding each one back.
- Findings written in business terms, with the evidence behind each one.
- A sequenced roadmap split into immediate, short term and consolidation work.
- An evidence register you can hand to an insurer, a client or an auditor.

Start with what you could not answer

Send us the self-check questions you could not answer. We will spend 30 minutes working through what they mean for your obligations and your exposure, at no cost and with no obligation afterwards. If the outcome is that you have more pressing priorities, we will say so.

Email	security@eviant.com.au
Web	www.eviant.com.au
Location	Sydney, New South Wales.
ABN	42 693 128 764

Version 1.0, published August 2026, written against the ASD Essential Eight Maturity Model dated 27 November 2023. Requirement summaries are Eviant's paraphrase; the authoritative text at cyber.gov.au takes precedence. General information, not legal advice. Free to share unmodified.